MW REALTY · TESTER HANDBOOK · PROJECT DOCUMENT P7

APIs & Batch Jobs

Every API, webhook, scheduled task and background job in MW Realty, with how to test and monitor each one.

Scope: The public website API (/api/...), the partner CRM API (/api/crm/...) and the two mobile apps that reuse them, inbound webhooks (Stripe, Facebook), the Laravel scheduler, queued jobs, the Artisan commands QA may need, sample log lines and job-health checks. Built from the routes, middleware, config and code on the crm-api branch. All values in examples are fake.

1. API overview

1.1 API groups

Group	Base path	Who calls it	Auth	Docs
Public website API	`/api/...` (content, search, forms, leads, AI chat, compare)	The Vue website SPA and the customer mobile app	None for content. Customer-only endpoints need a Sanctum Bearer token (`auth:sanctum`).	`/docs/frontend`
Customer account API	`/api/auth/...`, `/api/customer/...`	Customer mobile app	Sanctum personal access token: `Authorization: Bearer {token}` from `POST /api/auth/login`, `/api/auth/verify-otp` or `/api/auth/google`. Tokens do not expire; logout revokes the current one.	`/docs/app-customer` (app subset)
CRM API	`/api/crm/...`	The partner CRM web app at `/crm` (agents, agencies, Super Admin) and the agent mobile app	`crm.auth`: either a Sanctum Bearer token from `POST /api/crm/auth/login` (mobile), or the browser session of the CRM web app (portal session, or a Super Admin's admin session for the global view). Most endpoints also need `portal.2fa` (2FA step done) and `portal.approved` (KYC approved); some need a plan feature.	`/docs/crm`, `/docs/app-agent` (app subset)
Agent mobile app	Subset of `/api/crm/...`	Agent app	Same as CRM API, Bearer token	`/docs/app-agent`
Customer mobile app	Subset of `/api/...`	Customer app	Guest, or Bearer token; plus `X-Device-Id` header	`/docs/app-customer`
Tracking	`/api/track/...` (app) and `/track/...` (website)	App background calls; website page tracker and ad slider	None. Visitor identified by `X-Device-Id` (app) or the `mw_vid` cookie (website). The web `/track/*` routes are exempt from CSRF.	`/docs/frontend`
Webhooks	`/api/stripe/webhook`, `/api/webhooks/facebook`, `/api/webhooks/facebook/data-deletion`	Stripe, Meta (Facebook)	Signature checks inside the controller (Stripe-Signature header; Facebook X-Hub-Signature-256 or signed_request)	Not in the docs (excluded on purpose)
Website session routes	`/leads/*`, `/chatbot/*`, `/customer/*`, `/track/*` (no `/api` prefix)	The website itself	Laravel web session + CSRF token (except `/track/*`)	Not documented separately; same controllers as the API versions
Admin / CMS	`/admin/...`	Internal staff	Admin session (`cms.auth` + `cms.permission:*`)	Server-rendered Blade, not a JSON API; out of scope here
Health check	`/up`	Monitoring	None	Returns 200 when the app boots

1.2 Auth details testers should know

- Guards (config/auth.php): `web` (session, website customers), `portal` (session, agents and agencies). The admin uses its own `cms` guard. Sanctum checks the `web` guard for stateful requests and has `expiration => null`, so tokens never time out on their own.
- CRM token sign-in can return a next step instead of a token: email code for a new device (`/api/crm/auth/login/verify-email`) or 2FA (`/api/crm/auth/login/two-factor`). Test both paths.
- `401 Unauthenticated.` means no or invalid token/session. `403` on CRM endpoints usually means the account is not approved yet, 2FA is pending, the plan lacks the feature, or the endpoint is Super Admin only.
- The CRM web app uses Sanctum's stateful middleware: the browser must call `GET /sanctum/csrf-cookie` and send the XSRF token, exactly as the Vue app does.

1.3 Rate limits

Named limiters are defined in app/Providers/AppServiceProvider.php. Plain `throttle:N,1` means N requests per minute per IP (or per signed-in user). A blocked request gets HTTP 429 in the normal JSON envelope.

Limiter	Limit	Key	Used on
admin-login	5/min per email+IP and 30/min per IP	email + IP	Admin login, CRM login, customer login, Google sign-in
portal-registration	10/hour	IP	Customer registration
otp-verify	8/min and 30/day	IP	OTP verify/resend, 2FA, email change, password-reset email check
form-submit	20/hour	IP	Contact form (incl. calculator and compare unlock forms), newsletter, careers apply, forgot/reset password
lead-capture	20/hour	IP	All lead forms, chatbot start
landing-page-enquiry	20/hour	IP	`POST /{slug}/enquiry`
ai-chatbot	8/min and 150/day	IP	`POST /api/chatbot/message` (paid AI call)
ai-compare	10/min and 100/day	IP	`GET /api/compare/summary`
throttle:120,1 / 240,1 / 60,1 / 30,1 / 20,1 / 10,1	per minute	IP or user	Pickers, tracking, polling status, imports, payments (see Notes column in section 2)
throttle:600,1	600/min	IP	Facebook webhook

> QA tip: limits are per IP, so a whole test team behind one office IP shares the same counters. Expect 429s when several testers hammer lead forms or OTP screens at once; clear the cache (`php artisan cache:clear`) on QA to reset counters if needed.

1.4 Response format

- Every `/api/*` response (success and error, including unknown-route 404s) is wrapped by App\Support\ApiEnvelope: `{ "success": true|false, "message": "...", "data": ... }`.
- Paginated lists come in two shapes:
  - Lists returned as a Laravel paginated resource collection come back as `data: { items, meta, links }`.
  - The public website page endpoints (for example `GET /api/properties`, `/api/commercial`, `/api/blogs`, `/api/market-insights`) return their own list key plus a `pagination` object. For example, `GET /api/properties` returns `data: { properties: [...], pagination: { current_page, last_page, total }, filters, seo, ... }`. The website and the mobile app read this shape.
- Validation errors: HTTP 422 with `success: false`, `data: null` and `errors: { field: [messages] }`.
- `/api/*` always answers in JSON even without an `Accept: application/json` header. The CRM group also forces JSON.
- Webhook endpoints are excluded from the envelope (third parties expect plain replies such as `OK` or `EVENT_RECEIVED`).
- Language: send `?lang=en` or `?lang=ar` on content endpoints (`GET /api/languages` lists them). Prices are stored in AED; `GET /api/currencies` gives display rates.
- App headers: `Accept: application/json`, `X-Device-Id` (16 to 60 letters, digits or dashes, stable per install), `Authorization: Bearer {token}` when signed in, and a `User-Agent` (requests without one are treated as bots and not tracked).

1.5 API documentation (Scribe)

Docs	URL	Built from	Raw files
Website / frontend API	`/docs/frontend`	config/scribe.php (all `/api/*` except CRM and webhooks)	`/docs/_scribe/frontend/openapi.yaml`, `/docs/_scribe/frontend/collection.json`
CRM API	`/docs/crm`	config/scribe_crm.php (`/api/crm/*`)	`/docs/_scribe/crm/openapi.yaml`, `/docs/_scribe/crm/collection.json`
Customer app	`/docs/app-customer`	config/scribe_app_customer.php (endpoints grouped by app tab)	`/docs/_scribe/app-customer/openapi.yaml`, `/docs/_scribe/app-customer/collection.json`
Agent app	`/docs/app-agent`	config/scribe_app_agent.php (endpoints grouped by app tab)	`/docs/_scribe/app-agent/openapi.yaml`, `/docs/_scribe/app-agent/collection.json`

- How they are served: plain static files in public/docs. Each `/docs/{name}/index.html` loads the Scalar API viewer from cdn.jsdelivr.net and points it at the matching `openapi.yaml`. There is no Laravel route for `/docs`, so the docs work on any web server that serves public/.
- Postman: each folder has a Postman v2 collection (`collection.json`) and an OpenAPI 3 spec (`openapi.yaml`). Import either into Postman, Bruno or Insomnia, then set the `baseUrl` variable to the QA host.
- Regenerate with `php artisan docs:generate` (developer task; it clears config and rewrites public/docs/_scribe). At the time of writing the CRM collection holds 230 requests while the route list has 251 CRM routes, so ask a developer to regenerate before importing if an endpoint is missing.

2. Endpoint list

Auth column legend: Public = no login; Token = Sanctum Bearer token; Session = website session + CSRF; CRM = `crm.auth` (Bearer token or CRM browser session); + 2FA = two-factor step must be complete; + Approved = account KYC approved. "Agent app" or "Customer app" in Notes marks endpoints the mobile app calls. Limits are listed in section 1.3.

2.1 Public website API: content and search

Method	Path	Purpose	Auth	Notes
GET	`/api/home`	Whole home page in one call	Public	Customer app
GET	`/api/home/new-projects`	Home "New Projects" tab by city (`?city=`)	Public	Customer app
GET	`/api/property-filters`	Search filter bar options	Public	Customer app
GET	`/api/search-filters/{page}`	Filters configured for one listing page	Public	Customer app
GET	`/api/location-suggestions`	Location autocomplete	Public	Limit 120/min; Customer app
GET	`/api/properties`	Property listing (filters, paging; `?premium=1` for featured)	Public	Customer app
GET	`/api/properties/map`	Map pins for the visible area	Public	Limit 120/min; Customer app
GET	`/api/properties/{slug}`	Property details	Public	Customer app
GET	`/api/properties/{slug}/insights`	Market and investment panel	Public	Limit 60/min
GET	`/api/commercial`	Commercial listing page	Public	Customer app
GET	`/api/compare`	Compare 2 to 5 listings. Without a valid `X-Compare-Unlock` header: `locked: true` and `costs`, `total_outlay`, `market` are null	Public	Limit 60/min
GET	`/api/compare/summary`	AI written comparison; written without the locked figures unless `X-Compare-Unlock` is valid	Public	Limit: ai-compare; cached per listing set
GET	`/api/agents`	Agents listing	Public	

Method	Path	Purpose	Auth	Notes
GET	`/api/agents/{slug}`	Agent profile	Public	
GET	`/api/agencies`	Agencies listing	Public	
GET	`/api/agencies/{slug}`	Agency profile	Public	
GET	`/api/blogs`	Blog list (paged)	Public	
GET	`/api/blogs/{slug}`	Blog post	Public	
GET	`/api/landing-pages/{slug}`	Blog-design landing page	Public	
GET	`/api/market-insights`	Market insights list	Public	
GET	`/api/market-insights/{slug}`	Market insight article	Public	
GET	`/api/careers`	Vacancies	Public	
GET	`/api/careers/{slug}`	One vacancy	Public	
GET	`/api/about`	About page	Public	
GET	`/api/contact`	Contact page content	Public	
GET	`/api/legal/{key}`	Legal page: terms, privacy, security, cookie	Public	Customer app
GET	`/api/site-information`	Footer contact details and social links	Public	Customer app
GET	`/api/calculators`	Calculator pages copy and settings	Public	
GET	`/api/calculators/{key}`	One calculator	Public	Customer app
GET	`/api/languages`	Available languages (en, ar)	Public	Customer app
GET	`/api/static-translations`	UI copy for `?lang=`	Public	Customer app
GET	`/api/currencies`	Currency switcher rates (per 1 AED)	Public	Customer app
GET	`/api/ads`	One ad slot (`?placement=`)	Public	Customer app
GET	`/api/ads/slides`	All ads for a page slider	Public	Customer app

2.2 Public website API: forms, leads, AI chat, tracking

Method	Path	Purpose	Auth	Notes
POST	`/api/contact`	Contact form; saves enquiry, emails admin, creates a Website Lead. `source=compare` (the /compare unlock form) also returns `compare_unlock` , the token for the `X-Compare-Unlock` header (valid 365 days)	Public	Limit: form-submit
POST	`/api/newsletter/subscribe`	Newsletter sign-up	Public	Limit: form-submit
POST	`/api/careers/apply`	Job application with CV	Public	Limit: form-submit
POST	`/api/leads/capture`	Property enquiry; routed to the listing owner	Public (token optional)	Limit: lead-capture; Customer app
POST	`/api/leads/viewing`	Viewing request	Public (token optional)	Limit: lead-capture; Customer app
POST	`/api/leads/brochure-download`	Lead + signed brochure link	Public	Limit: lead-capture

Method	Path	Purpose	Auth	Notes
POST	`/api/leads/floor-plan-download`	Lead + signed floor plan link	Public	Limit: lead-capture
POST	`/api/leads/custom-request`	"Custom request" lead (unassigned)	Public	Limit: lead-capture
POST	`/api/leads/profile-request`	Enquiry from an agent/agency profile	Public	Limit: lead-capture
GET	`/api/chatbot/session`	Current AI chat conversation	Public	Limit 60/min; needs `X-Device-Id`
POST	`/api/chatbot/start`	Start chat (name/contact)	Public	Limit: lead-capture
POST	`/api/chatbot/reset`	Clear the conversation	Public	Limit 30/min
POST	`/api/chatbot/message`	Send a message (AI reply)	Public	Limit: ai-chatbot
POST	`/api/track/page`	Page or property view	Public	Limit 120/min; Customer app
POST	`/api/track/page/{event}/time`	Time spent on a page	Public	Limit 240/min; Customer app
POST	`/api/track/impressions`	Listing cards seen	Public	Limit 120/min; Customer app
POST	`/api/track/lead-click`	Contact button click on a listing	Public	Limit 60/min; Customer app
POST	`/api/track/ad-impressions`	Ad slides seen	Public	Limit 120/min; Customer app
POST	`/api/track/ad-click`	Ad click	Public	Limit 60/min; Customer app

2.3 Customer account API (customer mobile app)

Method	Path	Purpose	Auth	Notes
POST	`/api/auth/register`	Register; emails a 4-digit code	Public	Limit: portal-registration
POST	`/api/auth/verify-otp`	Verify code; returns token	Public	Limit: otp-verify
POST	`/api/auth/resend-otp`	Resend code	Public	Limit: otp-verify
POST	`/api/auth/login`	Email + password; returns token	Public	Limit: admin-login
POST	`/api/auth/google`	Native Google Sign-In token; returns token	Public	Limit: admin-login
POST	`/api/auth/forgot-password`	Send reset email	Public	Limit: form-submit
POST	`/api/auth/reset-password`	Set new password	Public	Limit: form-submit
POST	`/api/auth/logout`	Revoke current token	Token	
GET	`/api/customer/session`	Signed-in state for the current device or token	Public	Guests get `authenticated: false`, not 401
GET	`/api/customer/me`	Profile and account data (saved items, activity)	Token	
PUT	`/api/customer/settings`	Update profile/settings	Token	
POST	`/api/customer/settings`	Same, multipart (avatar upload)	Token	Use POST for file uploads

Method	Path	Purpose	Auth	Notes
DELETE	`/api/customer/account`	Delete account	Token	
GET	`/api/customer/wishlist`	Saved properties	Token	
POST	`/api/customer/wishlist/{property}`	Toggle saved property	Token	
POST	`/api/customer/saved-searches`	Save a search	Token	
DELETE	`/api/customer/saved-searches/{savedSearch}`	Delete a saved search	Token	

2.4 Website-only session routes (same controllers, no /api prefix)

Method	Path	Purpose	Auth	Notes
POST	`/leads/capture`, `/leads/viewing`, `/leads/brochure-download`, `/leads/floor-plan-download`, `/leads/custom-request`, `/leads/profile-request`	Website lead forms	Session + CSRF	Limit: lead-capture
GET	`/downloads/property/{property}/{kind}`	Brochure/floor plan file	Signed URL	Limit 30/min; link expires
GET, POST	`/chatbot/session`, `/chatbot/start`, `/chatbot/reset`, `/chatbot/message`	Website AI chat widget	Session + `mw_vid` cookie	Same limits as API
POST	`/track/page`, `/track/page/{event}/time`, `/track/impressions`, `/track/lead-click`, `/track/insight-view`, `/track/ad-impressions`, `/track/ad-click`	Website tracker	No CSRF (beacons)	Limits 60 to 240/min
POST	`/customer/register`, `/customer/login`, `/customer/verify-otp`, `/customer/resend-otp`, `/customer/forgot-password`, `/customer/forgot-password/check-email`, `/customer/reset-password`, `/customer/logout`	Website customer auth	Session + CSRF	Same limiters as the API
GET	`/customer/auth/google`, `/customer/auth/google/callback`	Google OAuth (website)	Public	Redirect flow
GET, PUT, POST, DELETE	`/customer/session`, `/customer/me`, `/customer/settings`, `/customer/wishlist/{property}`, `/customer/saved-searches/{id}`	Website profile page data	Session (`customer.auth`)	401 JSON for guests
POST	`/{slug}/enquiry`	Landing page enquiry form	Session + CSRF	Limit: landing-page-enquiry
GET	`/newsletter/unsubscribe/{token}`	Newsletter unsubscribe link	Public	
GET	`/integrations/facebook/callback`	Facebook Login return (CRM connect Pages)	Public (OAuth state)	Limit 30/min
GET	`/facebook/data-deletion`	Data deletion status page (`?code=`)	Public	Limit 60/min

The CRM API tables below list all 251 /api/crm routes, grouped by CRM module. Every route except the four sign-in steps needs crm.auth. Super Admin only means the controller returns 403 for agents and agencies.

2.5 CRM API: Sign-in (6)

Method	Path	Purpose	Auth	Notes
POST	`/api/crm/auth/login`	Sign in (email + password); returns token or next step	Public	Limit: admin-login; Agent app

Method	Path	Purpose	Auth	Notes
POST	`/api/crm/auth/login/resend-email`	Resend the new-device email code	Public	Limit: otp-verify; Agent app
POST	`/api/crm/auth/login/two-factor`	Finish sign-in with 2FA or recovery code	Public	Limit: otp-verify; Agent app
POST	`/api/crm/auth/login/verify-email`	Finish sign-in with the emailed device code	Public	Limit: otp-verify; Agent app
POST	`/api/crm/auth/logout`	Sign out (revokes the token)	CRM	Agent app
GET	`/api/crm/auth/me`	Signed-in account, plan, permissions, onboarding gaps	CRM	Agent app

2.6 CRM API: Two-factor (account security) (8)

Method	Path	Purpose	Auth	Notes
GET	`/api/crm/account/two-factor`	Two-factor status of the signed-in account	CRM	Agent app
POST	`/api/crm/account/two-factor/confirm`	Confirm authenticator code and turn 2FA on	CRM	Limit: otp-verify; Agent app
POST	`/api/crm/account/two-factor/disable`	Turn 2FA off (needs current code)	CRM	Limit: otp-verify
POST	`/api/crm/account/two-factor/enforce`	Agency: require 2FA for its agents	CRM	
POST	`/api/crm/account/two-factor/forget-devices`	Forget remembered devices	CRM	
POST	`/api/crm/account/two-factor/recovery-codes`	Regenerate recovery codes	CRM	Limit: otp-verify
POST	`/api/crm/account/two-factor/setup`	Start 2FA set-up (QR secret)	CRM	Limit: otp-verify; Agent app
POST	`/api/crm/account/two-factor/skip`	Skip the optional 2FA prompt	CRM	Agent app

2.7 CRM API: Dashboard, navigation, help, notifications, lead and property insights (10)

Method	Path	Purpose	Auth	Notes
GET	`/api/crm/dashboard`	Dashboard figures	CRM + 2FA	Agent app
GET	`/api/crm/help`	Help topics	CRM	
POST	`/api/crm/help/seen`	Mark help as seen	CRM	
GET	`/api/crm/help/{topic}`	One help topic	CRM	
GET	`/api/crm/lead-insights`	Lead insights report	CRM + 2FA + Approved	Plan feature: lead_insights
GET	`/api/crm/property-insights`	Property insights: every listing on the market with impressions, clicks, lead clicks, leads and quality for the period; totals; day-by-day series. Query: days (7/30/90), sort (impressions/clicks/leads/no_views/newest), segment, search, page	CRM + 2FA + Approved	Plan feature: property_insights
GET	`/api/crm/navigation`	Sidebar menu for this account	CRM	
GET	`/api/crm/notifications`	Bell notifications	CRM	Agent app
POST	`/api/crm/notifications/read-all`	Mark all read	CRM	Agent app
POST	`/api/crm/notifications/{id}/read`	Mark one read	CRM	Agent app

2.8 CRM API: My profile and KYC (11)

Method	Path	Purpose	Auth	Notes
GET	`/api/crm/profile`	Profile and KYC documents	CRM + 2FA	Agent app
POST	`/api/crm/profile`	Save profile	CRM + 2FA	Agent app

Method	Path	Purpose	Auth	Notes
POST	`/api/crm/profile/avatar`	Upload avatar	CRM + 2FA	Agent app
DELETE	`/api/crm/profile/avatar`	Remove avatar	CRM + 2FA	Agent app
GET	`/api/crm/profile/brokerages`	Brokerage picker	CRM + 2FA	Limit 120/min; Agent app
GET	`/api/crm/profile/documents/{field}`	View a KYC document	CRM + 2FA	Agent app
POST	`/api/crm/profile/documents/{field}`	Upload a KYC document	CRM + 2FA	Agent app
DELETE	`/api/crm/profile/documents/{field}`	Remove a KYC document	CRM + 2FA	Agent app
POST	`/api/crm/profile/email/request`	Request email change (sends code)	CRM + 2FA	Limit: otp-verify; Agent app
POST	`/api/crm/profile/email/verify`	Verify email change code	CRM + 2FA	Limit: otp-verify; Agent app
POST	`/api/crm/profile/submit`	Submit profile for approval	CRM + 2FA	Agent app

2.9 CRM API: Plans, checkout and invoices (15)

Method	Path	Purpose	Auth	Notes
GET	`/api/crm/plans`	Plans and current subscription	CRM + 2FA + Approved	
POST	`/api/crm/plans`	Choose a plan (request or checkout)	CRM + 2FA + Approved	
POST	`/api/crm/plans/billing-portal`	Open Stripe billing portal	CRM + 2FA	
POST	`/api/crm/plans/change-preview`	Preview price of a plan change	CRM + 2FA + Approved	
GET	`/api/crm/plans/checkout`	Checkout page data	CRM + 2FA + Approved	
POST	`/api/crm/plans/checkout/complete`	Confirm on-site checkout	CRM + 2FA + Approved	
POST	`/api/crm/plans/checkout/intent`	Start on-site card payment	CRM + 2FA + Approved	Limit 10/min
POST	`/api/crm/plans/checkout/session`	Start Stripe-hosted checkout	CRM + 2FA	
POST	`/api/crm/plans/coupon-check`	Validate a coupon	CRM + 2FA + Approved	Limit 20/min
GET	`/api/crm/plans/payments`	Payment history	CRM + 2FA	
GET	`/api/crm/plans/payments/{id}/invoice`	Invoice (HTML)	CRM + 2FA	
GET	`/api/crm/plans/payments/{id}/invoice.pdf`	Invoice PDF	CRM + 2FA	
POST	`/api/crm/plans/subscription/cancel`	Cancel at period end	CRM + 2FA	
POST	`/api/crm/plans/subscription/keep-plan`	Keep current plan (drop pending change)	CRM + 2FA + Approved	
POST	`/api/crm/plans/subscription/resume`	Resume a cancelled subscription	CRM + 2FA	

2.10 CRM API: Leads, follow-ups, imports (41)

Method	Path	Purpose	Auth	Notes
GET	`/api/crm/leads`	Leads list (filters, paging)	CRM + 2FA + Approved	Agent app
POST	`/api/crm/leads`	Create a lead	CRM + 2FA + Approved	
GET	`/api/crm/leads/assignment-settings`	Round-robin settings	CRM + 2FA + Approved	
PUT	`/api/crm/leads/assignment-settings`	Save round-robin settings	CRM + 2FA + Approved	

Method	Path	Purpose	Auth	Notes
POST	`/api/crm/leads/bulk/delete`	Bulk delete	CRM + 2FA + Approved	
POST	`/api/crm/leads/bulk/stage`	Bulk change stage	CRM + 2FA + Approved	
POST	`/api/crm/leads/bulk/tags`	Bulk tag	CRM + 2FA + Approved	
POST	`/api/crm/leads/distribute`	Distribute unassigned leads	CRM + 2FA + Approved	
POST	`/api/crm/leads/export`	Export leads	CRM + 2FA + Approved	
GET	`/api/crm/leads/follow-ups`	Follow-ups list	CRM + 2FA + Approved	
PUT	`/api/crm/leads/follow-ups/{id}`	Edit a follow-up	CRM + 2FA + Approved	
POST	`/api/crm/leads/follow-ups/{id}/cancel`	Cancel a follow-up	CRM + 2FA + Approved	
POST	`/api/crm/leads/follow-ups/{id}/complete`	Complete a follow-up	CRM + 2FA + Approved	
POST	`/api/crm/leads/imports`	Upload a lead file (imports queue)	CRM + 2FA + Approved	
GET	`/api/crm/leads/imports/facebook-sample`	Download Facebook CSV sample	CRM + 2FA + Approved	
GET	`/api/crm/leads/imports/template`	Download import template	CRM + 2FA + Approved	
GET	`/api/crm/leads/imports/{leadImport}`	Import progress (polled)	CRM + 2FA + Approved	Limit 120/min
GET	`/api/crm/leads/imports/{leadImport}/result`	Download import result file	CRM + 2FA + Approved	
GET	`/api/crm/leads/meta`	Filters, stages, sources, tags, columns	CRM + 2FA + Approved	Agent app
GET	`/api/crm/leads/options/{type}`	Master-data options (search, paged)	CRM + 2FA + Approved	Agent app
GET	`/api/crm/leads/owner-options`	Owner/agent picker	CRM + 2FA + Approved	
PUT	`/api/crm/leads/table-columns`	Save visible columns	CRM + 2FA + Approved	
GET	`/api/crm/leads/trashed`	Deleted leads	CRM + 2FA + Approved	
POST	`/api/crm/leads/trashed/bulk`	Bulk restore/purge	CRM + 2FA + Approved	
DELETE	`/api/crm/leads/trashed/{id}`	Delete permanently	CRM + 2FA + Approved	
POST	`/api/crm/leads/trashed/{id}/restore`	Restore a lead	CRM + 2FA + Approved	
GET	`/api/crm/leads/{id}`	One lead	CRM + 2FA + Approved	Agent app

Method	Path	Purpose	Auth	Notes
PUT	`/api/crm/leads/{id}`	Update a lead	CRM + 2FA + Approved	
PATCH	`/api/crm/leads/{id}`	Update some fields	CRM + 2FA + Approved	Agent app
DELETE	`/api/crm/leads/{id}`	Move lead to trash	CRM + 2FA + Approved	
POST	`/api/crm/leads/{id}/assign`	Assign to agent	CRM + 2FA + Approved	Agent app
POST	`/api/crm/leads/{id}/contacts`	Add contact	CRM + 2FA + Approved	Agent app
DELETE	`/api/crm/leads/{id}/contacts/{contactId}`	Remove contact	CRM + 2FA + Approved	
PUT	`/api/crm/leads/{id}/contacts/{contactId}/primary`	Set primary contact	CRM + 2FA + Approved	Agent app
GET	`/api/crm/leads/{id}/follow-ups`	A lead's follow-ups	CRM + 2FA + Approved	
POST	`/api/crm/leads/{id}/follow-ups`	Add follow-up	CRM + 2FA + Approved	
GET	`/api/crm/leads/{id}/insights`	Lead activity insights	CRM + 2FA + Approved	Limit 120/min
GET	`/api/crm/leads/{id}/insights/summary`	AI summary of the lead's activity	CRM + 2FA + Approved	
POST	`/api/crm/leads/{id}/notes`	Add note	CRM + 2FA + Approved	Agent app
PUT	`/api/crm/leads/{id}/stage`	Change stage	CRM + 2FA + Approved	Agent app
PUT	`/api/crm/leads/{id}/tags`	Replace tags	CRM + 2FA + Approved	Agent app

2.11 CRM API: Website leads (Super Admin) (6)

Method	Path	Purpose	Auth	Notes
GET	`/api/crm/website-leads`	Website leads pool	CRM + 2FA	Super Admin only
POST	`/api/crm/website-leads/transfer`	Transfer to agency/agent	CRM + 2FA	Super Admin only
GET	`/api/crm/website-leads/transfer-targets`	Transfer target picker	CRM + 2FA	Super Admin only; Limit 120/min
GET	`/api/crm/website-leads/{websiteLead}`	One website lead	CRM + 2FA	Super Admin only
GET	`/api/crm/website-leads/{websiteLead}/insights`	Visitor activity	CRM + 2FA	Super Admin only; Limit 120/min
GET	`/api/crm/website-leads/{websiteLead}/insights/summary`	AI summary	CRM + 2FA	Super Admin only

2.12 CRM API: Properties (listings) (32)

Method	Path	Purpose	Auth	Notes
GET	`/api/crm/properties`	Listings list	CRM + 2FA + Approved	Agent app
POST	`/api/crm/properties`	Create listing (multipart)	CRM + 2FA + Approved	Agent app
GET	`/api/crm/properties/agent-options`	Agent picker	CRM + 2FA + Approved	Limit 120/min; Agent app
POST	`/api/crm/properties/bulk-action`	Bulk publish/unpublish/delete	CRM + 2FA + Approved	
GET	`/api/crm/properties/create`	Form data for new listing	CRM + 2FA + Approved	Agent app
GET	`/api/crm/properties/imports`	Import history	CRM + 2FA + Approved	
POST	`/api/crm/properties/imports`	Upload listing spreadsheet	CRM + 2FA + Approved	Limit 20/min
GET	`/api/crm/properties/imports/latest`	Latest import	CRM + 2FA + Approved	
GET	`/api/crm/properties/imports/template`	Download template	CRM + 2FA + Approved	
GET	`/api/crm/properties/imports/{propertyImport}`	Import progress (polled)	CRM + 2FA + Approved	Limit 120/min
GET	`/api/crm/properties/imports/{propertyImport}/result`	Download result file	CRM + 2FA + Approved	
POST	`/api/crm/properties/imports/{propertyImport}/start`	Start the import (imports queue)	CRM + 2FA + Approved	
GET	`/api/crm/properties/nearby-places`	Nearby places for the form	CRM + 2FA + Approved	Agent app
POST	`/api/crm/properties/permit/validate`	Validate DLD permit number	CRM + 2FA + Approved	Limit 30/min; Agent app
POST	`/api/crm/properties/reorder`	Reorder listings	CRM + 2FA + Approved	
POST	`/api/crm/properties/translate`	Auto-translate fields (AI)	CRM + 2FA + Approved	Limit 60/min

Method	Path	Purpose	Auth	Notes
POST	`/api/crm/properties/write-copy`	AI title/description	CRM + 2FA + Approved	Limit 20/min
GET	`/api/crm/properties/{id}`	One listing	CRM + 2FA + Approved	Agent app
PUT	`/api/crm/properties/{id}`	Update listing	CRM + 2FA + Approved	Agent app
DELETE	`/api/crm/properties/{id}`	Delete listing	CRM + 2FA + Approved	
GET	`/api/crm/properties/{id}/edit`	Form data for edit	CRM + 2FA + Approved	Agent app
POST	`/api/crm/properties/{id}/feature`	Feature listing	CRM + 2FA + Approved	Agent app
PUT	`/api/crm/properties/{id}/feature`	Change featured period	CRM + 2FA + Approved	Agent app
DELETE	`/api/crm/properties/{id}/feature`	Stop featuring	CRM + 2FA + Approved	Agent app
DELETE	`/api/crm/properties/{id}/images`	Delete all photos	CRM + 2FA + Approved	
POST	`/api/crm/properties/{id}/images/reorder`	Reorder photos	CRM + 2FA + Approved	Agent app
DELETE	`/api/crm/properties/{id}/images/{number}`	Delete one photo	CRM + 2FA + Approved	Agent app
GET	`/api/crm/properties/{id}/insights`	Market and investment insights	CRM + 2FA + Approved	Plan feature: property_insights; Limit: 120,1,EnsurePlanIncludesFeature
POST	`/api/crm/properties/{id}/mark-sold`	Mark sold	CRM + 2FA + Approved	Agent app
POST	`/api/crm/properties/{id}/move`	Move to another agent/account	CRM + 2FA + Approved	
GET	`/api/crm/properties/{id}/sale-leads`	Leads to pick as buyer	CRM + 2FA + Approved	Agent app
POST	`/api/crm/properties/{id}/toggle-status`	Publish/unpublish	CRM + 2FA + Approved	Agent app

2.13 CRM API: Premium (featured) (3)

Method	Path	Purpose	Auth	Notes
GET	`/api/crm/premium`	Featured listings	CRM + 2FA + Approved	Agent app
POST	`/api/crm/premium`	Feature a listing (credits)	CRM + 2FA + Approved	Agent app
GET	`/api/crm/premium/eligible`	Listings that can be featured	CRM + 2FA + Approved	Limit 120/min; Agent app

2.14 CRM API: Advertisements (client bookings) (8)

Method	Path	Purpose	Auth	Notes
GET	`/api/crm/ads`	My ad bookings	CRM + 2FA + Approved	Agent app
POST	`/api/crm/ads`	Book an ad (charges credits)	CRM + 2FA + Approved	Agent app
GET	`/api/crm/ads/availability`	Free hours/days for a placement	CRM + 2FA + Approved	Limit 120/min; Agent app
GET	`/api/crm/ads/form-options`	Placements, plans and prices for the booking form	CRM + 2FA + Approved	Agent app
GET	`/api/crm/ads/properties`	My listings picker for an ad	CRM + 2FA + Approved	Limit 120/min; Agent app
GET	`/api/crm/ads/{id}`	One booking with impressions/clicks	CRM + 2FA + Approved	Agent app
PUT	`/api/crm/ads/{id}`	Change a pending booking	CRM + 2FA + Approved	Agent app
DELETE	`/api/crm/ads/{id}`	Cancel a booking	CRM + 2FA + Approved	Agent app

2.15 CRM API: Advertisements (Super Admin management) (13)

Method	Path	Purpose	Auth	Notes
GET	`/api/crm/ads/manage`	All ads (MW Realty and clients)	CRM + 2FA	Super Admin only
POST	`/api/crm/ads/manage`	Create an MW Realty ad	CRM + 2FA	Super Admin only
GET	`/api/crm/ads/manage/form-options`	Options for the admin ad form	CRM + 2FA	Super Admin only
GET	`/api/crm/ads/manage/placements`	Ad placement settings	CRM + 2FA	Super Admin only
PUT	`/api/crm/ads/manage/placements`	Save ad placement settings	CRM + 2FA	Super Admin only
GET	`/api/crm/ads/manage/properties`	Property picker for an ad	CRM + 2FA	Super Admin only; Limit 120/min
GET	`/api/crm/ads/manage/{id}`	One ad with report	CRM + 2FA	Super Admin only
PUT	`/api/crm/ads/manage/{id}`	Edit an ad	CRM + 2FA	Super Admin only
DELETE	`/api/crm/ads/manage/{id}`	Delete an ad	CRM + 2FA	Super Admin only
POST	`/api/crm/ads/manage/{id}/approve`	Approve a client ad	CRM + 2FA	Super Admin only
POST	`/api/crm/ads/manage/{id}/move`	Move a client ad to another slot	CRM + 2FA	Super Admin only
POST	`/api/crm/ads/manage/{id}/reject`	Reject a client ad (refund)	CRM + 2FA	Super Admin only
POST	`/api/crm/ads/manage/{id}/toggle`	Pause/resume an ad	CRM + 2FA	Super Admin only

2.16 CRM API: Credits (7)

Method	Path	Purpose	Auth	Notes
GET	`/api/crm/credits`	Credit balance and history	CRM + 2FA + Approved	Credits must be enabled; Agent app
POST	`/api/crm/credits/calculate`	Credit cost calculator	CRM + 2FA + Approved	Credits must be enabled; Limit 60/min

Method	Path	Purpose	Auth	Notes
GET	`/api/crm/credits/calculator`	Calculator options	CRM + 2FA + Approved	Credits must be enabled
GET	`/api/crm/credits/export`	Export credit history	CRM + 2FA + Approved	Credits must be enabled
GET	`/api/crm/credits/quote`	Price of a top-up	CRM + 2FA + Approved	Credits must be enabled; Limit 120/min; Agent app
POST	`/api/crm/credits/top-up/complete`	Confirm a Stripe top-up	CRM + 2FA + Approved	Credits must be enabled
POST	`/api/crm/credits/top-up/intent`	Start a Stripe top-up (PaymentIntent)	CRM + 2FA + Approved	Credits must be enabled; Limit 10/min

2.17 CRM API: Sold listings (3)

Method	Path	Purpose	Auth	Notes
GET	`/api/crm/sold-listings`	Sold listings	CRM + 2FA + Approved	Agent app
GET	`/api/crm/sold-listings/{id}/documents/{kind}`	Sale document	CRM + 2FA + Approved	Agent app
POST	`/api/crm/sold-listings/{id}/revert`	Revert to active	CRM + 2FA + Approved	

2.18 CRM API: Marketing properties (Super Admin) (6)

Method	Path	Purpose	Auth	Notes
GET	`/api/crm/marketing-properties`	Home "Realty" list	CRM + 2FA	Super Admin only
POST	`/api/crm/marketing-properties`	Add a listing	CRM + 2FA	Super Admin only
GET	`/api/crm/marketing-properties/accounts`	Account picker	CRM + 2FA	Super Admin only; Limit 120/min
GET	`/api/crm/marketing-properties/properties`	Listing picker	CRM + 2FA	Super Admin only; Limit 120/min
POST	`/api/crm/marketing-properties/reorder`	Reorder	CRM + 2FA	Super Admin only
DELETE	`/api/crm/marketing-properties/{propertyId}`	Remove a listing	CRM + 2FA	Super Admin only

2.19 CRM API: Agents (agency team) and Agent Insights (13)

Method	Path	Purpose	Auth	Notes
GET	`/api/crm/agents`	Agency: list its agents	CRM + 2FA + Approved	Agent app
POST	`/api/crm/agents`	Agency: create an agent account	CRM + 2FA + Approved	
GET	`/api/crm/agents/create`	Form data for new agent	CRM + 2FA + Approved	
POST	`/api/crm/agents/invite`	Invite an existing agent by email	CRM + 2FA + Approved	
GET	`/api/crm/agents/{id}`	One agent with stats	CRM + 2FA + Approved	Agent app
POST	`/api/crm/agents/{id}/accept-request`	Accept an agent join request	CRM + 2FA + Approved	
POST	`/api/crm/agents/{id}/cancel`	Cancel a pending invitation	CRM + 2FA + Approved	

Method	Path	Purpose	Auth	Notes
POST	`/api/crm/agents/{id}/decline-request`	Decline a join request	CRM + 2FA + Approved	
POST	`/api/crm/agents/{id}/reactivate`	Reactivate a suspended agent	CRM + 2FA + Approved	
POST	`/api/crm/agents/{id}/remove`	Remove agent from agency	CRM + 2FA + Approved	
POST	`/api/crm/agents/{id}/suspend`	Suspend an agent	CRM + 2FA + Approved	
GET	`/api/crm/agent-insights`	Agent insights: agents with response rate / time, untouched leads, overdue follow-ups, listings, Agent score; team totals. Query: days (7/30/90), sort (attention/name), search, page	CRM + 2FA + Approved	Agency or Super Admin; plan feature: agent_insights
GET	`/api/crm/agent-insights/{id}`	One agent (agent ID): score breakdown, untouched leads, overdue follow-ups, listings needing work. Query: days, leads_page, follow_ups_page, listings_page	CRM + 2FA + Approved	Agency (own agents only, else 404) or Super Admin; plan feature: agent_insights

2.20 CRM API: Nearby places (7)

Method	Path	Purpose	Auth	Notes
GET	`/api/crm/nearby-places`	Nearby places list	CRM + 2FA + Approved	
POST	`/api/crm/nearby-places`	Add place	CRM + 2FA + Approved	
GET	`/api/crm/nearby-places/form-options`	Form options	CRM + 2FA + Approved	
GET	`/api/crm/nearby-places/{id}`	One place	CRM + 2FA + Approved	
PUT	`/api/crm/nearby-places/{id}`	Edit place	CRM + 2FA + Approved	
DELETE	`/api/crm/nearby-places/{id}`	Delete place	CRM + 2FA + Approved	
POST	`/api/crm/nearby-places/{id}/toggle-status`	Activate/deactivate	CRM + 2FA + Approved	

2.21 CRM API: Listing settings (watermark) (4)

Method	Path	Purpose	Auth	Notes
GET	`/api/crm/listing-settings/watermark`	Watermark settings	CRM + 2FA + Approved	Plan feature: listing_settings
POST	`/api/crm/listing-settings/watermark`	Save watermark	CRM + 2FA + Approved	Plan feature: listing_settings
GET	`/api/crm/listing-settings/watermark/accounts`	Account picker (Super Admin)	CRM + 2FA + Approved	Plan feature: listing_settings
GET	`/api/crm/listing-settings/watermark/image`	Watermark image	CRM + 2FA + Approved	Plan feature: listing_settings

2.22 CRM API: Reports (2)

Method	Path	Purpose	Auth	Notes
GET	`/api/crm/reports/sales/export`	Export sales report	CRM + 2FA + Approved	
GET	`/api/crm/reports/{report?}`	Report (leads, properties, sales, revenue, agents)	CRM + 2FA + Approved	

2.23 CRM API: Help desk (support tickets) (8)

Method	Path	Purpose	Auth	Notes
GET	`/api/crm/support/meta`	Categories and priorities	CRM + 2FA	Agent app
GET	`/api/crm/support/tickets`	My tickets	CRM + 2FA	Agent app
POST	`/api/crm/support/tickets`	Open ticket	CRM + 2FA	Limit 10/min; Agent app
GET	`/api/crm/support/tickets/{ticket}`	One ticket	CRM + 2FA	Agent app
GET	`/api/crm/support/tickets/{ticket}/attachments/{message}`	Download attachment	CRM + 2FA	Agent app
POST	`/api/crm/support/tickets/{ticket}/reopen`	Reopen	CRM + 2FA	Agent app
POST	`/api/crm/support/tickets/{ticket}/reply`	Reply	CRM + 2FA	Limit 20/min; Agent app
POST	`/api/crm/support/tickets/{ticket}/resolve`	Mark resolved	CRM + 2FA	Agent app

2.24 CRM API: Listing permits (Super Admin) (4)

Method	Path	Purpose	Auth	Notes
GET	`/api/crm/listing-permits`	Listings by permit status	CRM + 2FA	Super Admin only
GET	`/api/crm/listing-permits/{id}`	One listing's permit	CRM + 2FA	Super Admin only
POST	`/api/crm/listing-permits/{id}/approve`	Approve permit	CRM + 2FA	Super Admin only
POST	`/api/crm/listing-permits/{id}/take-down`	Take listing down	CRM + 2FA	Super Admin only

2.25 CRM API: Listing review (Super Admin) (4)

Method	Path	Purpose	Auth	Notes
GET	`/api/crm/listing-review`	Flagged listings (duplicates, risk)	CRM + 2FA	Super Admin only
GET	`/api/crm/listing-review/{id}`	One review case	CRM + 2FA	Super Admin only
POST	`/api/crm/listing-review/{id}/approve`	Approve (goes live)	CRM + 2FA	Super Admin only
POST	`/api/crm/listing-review/{id}/reject`	Reject	CRM + 2FA	Super Admin only

2.26 CRM API: Integrations (Facebook, Property Finder) (17)

Method	Path	Purpose	Auth	Notes
GET	`/api/crm/integrations`	Integrations hub	CRM + 2FA + Approved	Plan feature: facebook or property_finder
GET	`/api/crm/integrations/facebook`	Facebook Lead Ads status	CRM + 2FA + Approved	Plan feature: facebook
GET	`/api/crm/integrations/facebook/accounts`	Account picker (Super Admin)	CRM + 2FA + Approved	Plan feature: facebook or ; Limit 120/min
POST	`/api/crm/integrations/facebook/bulk-disconnect`	Disconnect several Pages	CRM + 2FA + Approved	Plan feature: facebook
GET	`/api/crm/integrations/facebook/connect-url`	Facebook Login URL to connect Pages	CRM + 2FA + Approved	Plan feature: facebook
GET	`/api/crm/integrations/facebook/import-status`	Import progress (polled)	CRM + 2FA + Approved	Plan feature: facebook or ; Limit 120/min
POST	`/api/crm/integrations/facebook/pages`	Save the chosen Pages (starts import)	CRM + 2FA + Approved	Plan feature: facebook

Method	Path	Purpose	Auth	Notes
POST	`/api/crm/integrations/facebook/pages/cancel`	Cancel Page selection	CRM + 2FA + Approved	Plan feature: facebook
DELETE	`/api/crm/integrations/facebook/{id}`	Disconnect a Page	CRM + 2FA + Approved	Plan feature: facebook
POST	`/api/crm/integrations/facebook/{id}/sync`	Re-import a Page's leads	CRM + 2FA + Approved	Plan feature: facebook or ; Limit 10/min
GET	`/api/crm/integrations/property-finder`	Property Finder connection	CRM + 2FA + Approved	Plan feature: property_finder
POST	`/api/crm/integrations/property-finder`	Connect with API key + secret	CRM + 2FA + Approved	Plan feature: property_finder or ; Limit 10/min
DELETE	`/api/crm/integrations/property-finder`	Disconnect	CRM + 2FA + Approved	Plan feature: property_finder
GET	`/api/crm/integrations/property-finder/review`	Imported listings awaiting review	CRM + 2FA + Approved	Plan feature: property_finder
POST	`/api/crm/integrations/property-finder/review`	Approve/reject imported listings	CRM + 2FA + Approved	Plan feature: property_finder
GET	`/api/crm/integrations/property-finder/status`	Sync progress (polled)	CRM + 2FA + Approved	Plan feature: property_finder or ; Limit 120/min
POST	`/api/crm/integrations/property-finder/sync`	Start a sync (imports queue)	CRM + 2FA + Approved	Plan feature: property_finder or ; Limit 10/min

2.27 CRM API: Master data (stages, sources, tags, property options) (23)

Method	Path	Purpose	Auth	Notes
GET	`/api/crm/master/property-options`	Property option lists	CRM + 2FA + Approved	
POST	`/api/crm/master/property-options/{key}`	Add option	CRM + 2FA + Approved	
POST	`/api/crm/master/property-options/{key}/reorder`	Reorder options	CRM + 2FA + Approved	
PUT	`/api/crm/master/property-options/{key}/{id}`	Edit option	CRM + 2FA + Approved	
DELETE	`/api/crm/master/property-options/{key}/{id}`	Delete option	CRM + 2FA + Approved	
POST	`/api/crm/master/property-options/{key}/{id}/toggle`	Enable/disable option	CRM + 2FA + Approved	
GET	`/api/crm/master/sources`	Lead sources	CRM + 2FA + Approved	
POST	`/api/crm/master/sources`	Add source	CRM + 2FA + Approved	
POST	`/api/crm/master/sources/reorder`	Reorder sources	CRM + 2FA + Approved	
PUT	`/api/crm/master/sources/{id}`	Edit source	CRM + 2FA + Approved	
DELETE	`/api/crm/master/sources/{id}`	Delete source	CRM + 2FA + Approved	
GET	`/api/crm/master/stages`	Lead stages	CRM + 2FA + Approved	
POST	`/api/crm/master/stages`	Add stage	CRM + 2FA + Approved	
POST	`/api/crm/master/stages/reorder`	Reorder stages	CRM + 2FA + Approved	
PUT	`/api/crm/master/stages/{id}`	Edit stage	CRM + 2FA + Approved	
DELETE	`/api/crm/master/stages/{id}`	Delete stage	CRM + 2FA + Approved	
POST	`/api/crm/master/stages/{id}/default`	Set default stage	CRM + 2FA + Approved	
GET	`/api/crm/master/tags`	Tags	CRM + 2FA + Approved	

Method	Path	Purpose	Auth	Notes
POST	`/api/crm/master/tags`	Add tag	CRM + 2FA + Approved	
PUT	`/api/crm/master/tags/{id}`	Edit tag	CRM + 2FA + Approved	
DELETE	`/api/crm/master/tags/{id}`	Delete tag	CRM + 2FA + Approved	
GET	`/api/crm/master/{type}/{id}/leads`	Leads using a stage/source/tag	CRM + 2FA + Approved	
POST	`/api/crm/master/{type}/{id}/leads/remove`	Unlink leads before delete	CRM + 2FA + Approved	

3. Webhooks and inbound integrations

3.1 Stripe (plan subscriptions and credit top-ups)

Item	Detail
Endpoint	`POST /api/stripe/webhook` (route name stripe.webhook)
Security	Verifies the `Stripe-Signature` header with `STRIPE_WEBHOOK_SECRET`. If the secret is not set the endpoint returns 404. Bad signature returns 400 `Invalid signature`.
Events handled	`checkout.session.completed` and `checkout.session.async_payment_succeeded` (fulfil a hosted checkout); `invoice.paid` (record payment + invoice); `invoice.payment_failed` (mark payment failed); `payment_intent.succeeded` with metadata kind `credit_topup` (add credits); `customer.subscription.created` / `updated` (apply plan, fulfil on-site upgrade); `customer.subscription.deleted` (end subscription). Other events are ignored with 200.
Replies	200 `OK`; 500 `Handler error` when a handler throws (Stripe retries). Handlers are idempotent, so retries and duplicates are safe.
Triggered by	CRM Plans (checkout, upgrade, cancel/resume, billing portal) and Credits top-up.

How to test in QA:

- Use Stripe test mode keys only on QA. Card `4242 4242 4242 4242`, any future date, any CVC. Use `4000 0000 0000 9995` for a decline and `4000 0025 0000 3155` for 3-D Secure.
- QA / UAT: install the Stripe CLI, run `stripe login`, then `stripe listen --forward-to https://mw.realty.mightywarnersdemo.com/api/stripe/webhook`. The CLI prints a `whsec_...` signing secret; a developer puts it in the QA `.env` as `STRIPE_WEBHOOK_SECRET` and runs `php artisan config:clear`.
- Public QA host: add the endpoint in the Stripe test dashboard (Developers, Webhooks) with the events above.
- Best test is a real end-to-end flow (buy a plan in the CRM, top up credits) and then check CRM Plans/Payments and Credits. `stripe trigger invoice.paid` sends a generic event that does not match any QA account, so it only proves the endpoint answers.
- Negative test: `POST /api/stripe/webhook` with no signature header must return 400 and log `Stripe webhook rejected`.
- Re-send an event from the Stripe dashboard to confirm idempotency (no duplicate payment row, no double credits).

3.2 Facebook Lead Ads (leadgen webhook)

Item	Detail
Verify handshake	`GET /api/webhooks/facebook?hub_mode=subscribe&hub_verify_token={token}&hub_challenge={n}` echoes `{n}` as plain text when the token matches `FACEBOOK_WEBHOOK_VERIFY_TOKEN`, otherwise 403 `Forbidden`.
Events	`POST /api/webhooks/facebook`: checks `X-Hub-Signature-256` (HMAC-SHA256 of the raw body with the Meta app secret). Invalid signature returns 403. For each `leadgen` change it queues `ImportFacebookLead(page_id, leadgen_id)` and replies 200 `EVENT_RECEIVED`.
What the job does	Reads the lead from the Graph API with the connected Page's token and creates the CRM lead for that account (duplicates skipped). Page not connected: logged and ignored.
Related	CRM Integrations, Facebook: connect Pages via Facebook Login (`/integrations/facebook/callback`), initial import and manual re-sync run `ImportFacebookPageLeads`. Daily `facebook:check-page-tokens` flags Pages whose token stopped working.
Plan gate	The account's plan must include the `facebook` feature.

How to test in QA:

- Needs a Meta test app with Facebook Login and the Webhooks product (object Page, field leadgen) pointing at the QA host over HTTPS. For a local host use a tunnel such as ngrok.
- Use the Meta Lead Ads Testing Tool (developers.facebook.com/tools/lead-ads-testing): pick the connected test Page and form, Create lead, and watch the status turn to success. The lead should appear in CRM Leads with source Facebook within about a minute (queued job, worker runs every minute).
- Handshake test: call the GET URL with a wrong token and expect 403; with the right token expect the challenge echoed.
- Signature test: `POST` any JSON body without `X-Hub-Signature-256` and expect 403 `Invalid signature`.
- Disconnected Page: create a test lead for a Page not connected to any account; expect no lead and an info log line.

3.3 Facebook data deletion callback

Item	Detail
Endpoint	`POST /api/webhooks/facebook/data-deletion` (form field `signed_request`), limit 60/min
What it does	Validates the signed request, disconnects that Facebook user's Pages and returns JSON `{ url, confirmation_code }`.
Status page	`GET /facebook/data-deletion?code={confirmation_code}` shows the deletion status (404 for an unknown code).
How to test	In the Meta app settings set the Data Deletion Callback URL to the QA host, then remove the app from the test user's Facebook settings. Invalid `signed_request` must return 400.

3.4 Property Finder (outbound pull, no webhook)

- There is no inbound Property Finder endpoint. Each account enters its own Property Finder Enterprise API key and secret in CRM Integrations (`POST /api/crm/integrations/property-finder`).
- `POST /api/crm/integrations/property-finder/sync` queues `SyncPropertyFinderListings` on the `imports` queue; the page polls `/status`. Imported listings wait in a review list for Super Admin.
- Test with Property Finder sandbox credentials only; never real customer keys on QA.

3.5 Other inbound callbacks and outbound services

Service	Direction	Where	QA note
Google Sign-In	Inbound OAuth redirect (website), token check (app)	`/customer/auth/google/callback`, `POST /api/auth/google`	Needs the QA host as an authorised redirect URI in the Google console
Stripe return URLs	Browser redirect after hosted checkout	`/portal/...` routes with `?session_id=`	Older hosted checkouts; fulfilment also happens via webhook
Gemini (and Groq fallback) AI	Outbound	AI chat, compare summary, AI listing copy, lead summaries	Paid calls; respect rate limits; errors logged as `Gemini API error`
Google Translate / MyMemory	Outbound	Auto-translation of listings and bios	Failures logged, field left untranslated
Exchange-rate feed	Outbound	`currencies:sync-rates`	Only when `CURRENCY_RATES_AUTO_SYNC=true`
DLD permit validation	Outbound	`POST /api/crm/properties/permit/validate`	Failures logged with the permit number
Cloudinary	Outbound	All public media uploads and deletes	Use a separate QA folder/account
reCAPTCHA	Outbound	Public forms	Rejections logged as `reCAPTCHA rejected`

4. Scheduled jobs

The schedule is defined in bootstrap/app.php (`withSchedule`); routes/console.php only holds the default `inspire` command. The app timezone is UTC (config/app.php), so times without an explicit timezone are UTC (Dubai is UTC+4). The server needs one cron entry: `* * *`

`* * php /path/to/artisan schedule:run`.

Command	Schedule (timezone)	What it does	Condition / flag	How to run manually
`landing-pages:cleanup-temp-images`	Daily 00:00 UTC (04:00 Dubai)	Deletes unsaved landing-page editor images older than 24 h	`--hours=24` default	`php artisan landing-pages:cleanup-temp-images --hours=1`
`portal:notify-expiring-documents`	Daily 00:00 UTC	Emails agents/agencies whose passport, trade licence or TRN has expired	None	`php artisan portal:notify-expiring-documents`
`facebook:check-page-tokens`	Daily 08:00 UTC (12:00 Dubai)	Flags Facebook Pages whose token stopped working; emails owners to reconnect	withoutOverlapping	`php artisan facebook:check-page-tokens`
`portal:remind-subscription-renewals`	Daily 09:00 Asia/Dubai	Email + bell to accounts whose subscription auto-renews tomorrow	withoutOverlapping	`php artisan portal:remind-subscription-renewals`
`properties:expire-featured`	Every 15 minutes	Starts scheduled featured listings, un-features expired ones	None	`php artisan properties:expire-featured`
`leads:send-follow-up-reminders`	Every 5 minutes	Bell + email for lead follow-ups due in the next 15 minutes	withoutOverlapping	`php artisan leads:send-follow-up-reminders`
`credits:expire`	Hourly	Writes off credits past their validity (also done on the spot when a wallet is read)	withoutOverlapping	`php artisan credits:expire`
`ads:settle`	Every 15 minutes	Closes client ads still unreviewed when their booked time ended, and refunds credits	withoutOverlapping	`php artisan ads:settle`
`visitors:prune`	Daily 03:30 UTC (07:30 Dubai)	Deletes anonymous tracking events and chats older than 30 days, and unused browsers	withoutOverlapping	`php artisan visitors:prune`
`currencies:sync-rates`	Hourly	Refreshes currency rates from the live feed	Only if `CURRENCY_RATES_AUTO_SYNC=true` (off by default)	`php artisan currencies:sync-rates`
`properties:expire-permits`	Daily 00:05 Asia/Dubai	Unpublishes listings whose DLD permit expired; reminds 7 days before	withoutOverlapping	`php artisan properties:expire-permits`
Newsletter campaign (closure)	Every 15 minutes	Emails subscribers about blogs/insights whose publish date has arrived	Closure, not a command	`php artisan schedule:test` and pick it, or `schedule:run`
`queue:work --stop-when-empty --tries=3 --max-time=50`	Every minute	Drains the default queue (all emails and normal jobs)	withoutOverlapping; for hosts without Supervisor	`php artisan queue:work --stop-when-empty`
`queue:work imports --queue=imports --stop-when-empty --tries=1 --timeout=3600 --max-time=50`	Every minute	Separate worker for long imports (lead/listing files, Property Finder)	withoutOverlapping(90)	Same command by hand

> Because the queue is drained by the scheduler, emails and imports on QA can lag by up to about one minute. If nothing is processed at all, check that the cron for `schedule:run` is installed.

5. Queued jobs

Default queue connection is `database` (jobs table, `retry_after` 90 s). Long imports use the `imports` connection (same table, queue `imports`, `retry_after` 3700 s). In the tests (phpunit.xml) the queue runs synchronously.

Job	Triggered by	What it does	Retries / timeout	Failure behaviour
ImportFacebookLead	Facebook leadgen webhook	Fetches one lead from Graph API and adds it to the account's CRM	3 tries, backoff 60 s then 300 s	After 3 failures goes to failed_jobs; token errors flag the Page for reconnect
ImportFacebookPageLeads	Connecting Pages, catch-up after reconnect, manual Sync in CRM Integrations	Imports a Page's existing/missed leads; live progress on the Integrations page; summary email	1 try, 1800 s; runs after the HTTP response (`dispatchAfterResponse`), not via the worker	Error saved on the Page connection (`import_status = failed`), warning logged; no failed_jobs row
ProcessLeadImport	CRM Leads, Import (file upload)	Imports a lead file (10,000+ rows) on the imports queue; result file, summary emails, bell	1 try, 3600 s	`failed()` marks the import failed and logs an error; row errors written to the result file
ProcessPropertyImport	CRM Properties, Import, Start	Imports a listing spreadsheet (photos, AI copy) on the imports queue; result file, bell	1 try, 3600 s	`failed()` marks the import failed and logs an error
SyncPropertyFinderListings	CRM Integrations, Property Finder, Sync	Imports the account's Property Finder listings; bell to Super Admin to review	1 try, 3600 s, imports queue	`failed()` sets sync_status failed with the reason; warning logged
ScreenListingPhotos	Listing saved (Listing Review service)	Fingerprints photos and re-screens for duplicates across agencies	2 tries, 180 s	Goes to failed_jobs after 2 failures; screening without photos still applies
TranslatePortalBio	Profile bio saved in CRM	Auto-translates the agent/agency bio	3 tries, 120 s	Goes to failed_jobs; bio stays untranslated
RegenerateSeoFiles	Sitemap-listed content changes (if `SITEMAP_AUTO_REGENERATE` is on)	Rebuilds public/sitemap.xml and llms.txt	Unique for 60 s (bursts collapse to one); worker default 3 tries	Goes to failed_jobs; `sitemap:generate` can rebuild by hand
DeleteStoredFile	Replacing or deleting a managed file (after commit)	Deletes the old file from storage/Cloudinary	5 tries, backoff 10 s, 60 s, 300 s, 900 s	Goes to failed_jobs; orphan file remains
Queued mail (`Mail::to()->queue`)	Contact, careers, newsletter, new lead, lead assigned, follow-up reminder, imports, Facebook sync, KYC and listing compliance emails, landing page enquiries, newsletter campaigns	Sends the email via the configured mailer	Worker `--tries=3`	Goes to failed_jobs after 3 failures

Not queued: bell notifications (database channel, written in the request), OTP / new-device login codes, password reset and invoice emails, which are sent immediately so the user is not kept waiting.

6. Artisan commands for QA

"Safe" means it only does what the scheduler would do anyway. Anything marked Unsafe must only be run by a developer, never on a shared QA environment without agreement.

Command	Options	Safe on shared QA?
`ads:settle`	None	Safe (refunds unreviewed expired ads)
`credits:expire`	None	Safe
`properties:expire-featured`	None	Safe
`properties:expire-permits`	None	Safe, but unpublishes listings with expired permits and emails reminders
`leads:send-follow-up-reminders`	None	Safe (sends emails)
`portal:notify-expiring-documents`	None	Safe (sends emails to every affected account)
`portal:remind-subscription-renewals`	None	Safe (sends emails)
`facebook:check-page-tokens`	None	Safe (may email Page owners)
`landing-pages:cleanup-temp-images`	`--hours=24`	Safe
`visitors:prune`	None	Safe, but deletes anonymous tracking older than 30 days (affects stats tests that use old data)
`sitemap:generate`	None	Safe (rewrites public sitemap.xml, llms.txt, robots.txt)
`currencies:sync-rates`	None	Caution: overwrites rates typed in Admin
`properties:screen`	`--apply`, `--photos`	Dry run is safe. `--apply` takes flagged listings off the website
`leads:merge-duplicates`	`--dry-run`	Dry run safe. Without it merges leads permanently
`agency:sync-agent-plans`	None	Caution: moves every agency agent to the agency plan
`docs:generate`	None	Developer only (clears config, rewrites public/docs/_scribe)
`static-texts:import-edits`	`{dir}`, `--base=`	Developer only
`admin:provision`	`{email}`, `--name=`	Ops only: creates or resets a Super Admin
`admin:secure-existing-data`	None	Unsafe: replaces known default admin passwords and moves KYC files
`media:migrate-to-cloudinary`	`--dry-run`, `--skip-backup`, `--delete-local`, `--fix-folders`	Unsafe: one-off migration, runs mysqldump, can delete local files
`demo:media-to-cloudinary`	`--dry-run`, `--shard=i/n`	Unsafe: one-off for demo data
`schedule:list`, `schedule:test`		Safe (read-only list; test runs one chosen task)
`queue:failed`, `queue:retry`, `queue:monitor`		Safe
`migrate:fresh`, `test`		Never on shared QA (wipes or changes data)

7. Sample logs

All application logs go through the default `stack` channel. With the default `LOG_STACK=single` they are written to storage/logs/laravel.log; if `LOG_STACK=daily` they go to storage/logs/laravel-YYYY-MM-DD.log (kept 14 days). Format: `[date time]`

`environment.LEVEL: message {context}`. The `$this->info()` summaries of scheduled commands are console output only and are not written to the log. The lines below are representative examples with fake values, not copies of real logs.

Event	Sample log line (fake values)	Where it is written
Stripe webhook with bad signature	`[2026-11-02 08:14:03] qa.WARNING: Stripe webhook rejected: No signatures found matching the expected signature for payload`	laravel.log
Stripe handler failed (Stripe will retry)	`[2026-11-02 08:15:10] qa.ERROR: Stripe webhook invoice.paid (evt_TEST000111) failed: No query results for model [App\Models\PortalUser].`	laravel.log
Facebook lead for an unconnected Page	`[2026-11-02 09:01:22] qa.INFO: Facebook lead 900000000000001 for page 100000000000002: page isn't connected — ignored.`	laravel.log
Facebook Page import failed	`[2026-11-02 09:05:47] qa.WARNING: Facebook lead import for page 100000000000002 failed: cURL error 28: Operation timed out`	laravel.log
Facebook token check network error	`[2026-11-02 08:00:12] qa.INFO: Facebook token check for page 100000000000002 failed: Connection refused`	laravel.log
Lead import job failed	`[2026-11-02 10:20:31] qa.ERROR: Lead import 57 failed: The job has been attempted too many times.`	laravel.log, plus failed_jobs row
Lead import row error	`[2026-11-02 10:21:02] qa.ERROR: Lead import row 118 for owner 42 failed: SQLSTATE[22001]: String data, right truncated`	laravel.log, plus the import result file
Property import job failed	`[2026-11-02 11:02:45] qa.ERROR: Property import 12 failed: Maximum execution time of 3600 seconds exceeded`	laravel.log
Property import row error	`[2026-11-02 11:03:01] qa.WARNING: Property import row 7 failed: The location "Test Community" was not found.`	laravel.log
Property Finder sync failed	`[2026-11-02 12:00:40] qa.WARNING: Property Finder sync for account 42 failed: 401 Unauthorized`	laravel.log
Property Finder single listing skipped	`[2026-11-02 12:00:41] qa.WARNING: Property Finder listing PF-TEST-0001 import failed: Missing permit number`	laravel.log
Follow-up reminder failed	`[2026-11-02 12:05:00] qa.ERROR: Follow-up reminder #314 failed: Connection could not be established with host "smtp.example.test"`	laravel.log
Renewal reminder email failed	`[2026-11-02 05:00:03] qa.ERROR: Failed to send renewal reminder to portal user #42: Expected response code 250 but got 550`	laravel.log
Expired document email failed	`[2026-11-02 00:00:05] qa.ERROR: Failed to send passport expiry email to portal user #42: Connection timed out`	laravel.log
Newsletter campaign failed	`[2026-11-02 07:15:00] qa.ERROR: Newsletter campaign queue failed. {"content_type":"blog","content_id":9,"error":"Connection refused"}`	laravel.log
AI provider error	`[2026-11-02 13:30:09] qa.ERROR: Gemini API error: 429 {"error":{"message":"Resource exhausted (test)"}}`	laravel.log
Listing photo screening issue	`[2026-11-02 14:00:15] qa.WARNING: Listing Review: could not read photo test-photo-01.jpg: HTTP 404`	laravel.log
Permit validation failed (DLD or ADREC)	`[2026-11-02 14:10:22] qa.WARNING: DLD permit validation failed: cURL error 6: Could not resolve host {"permit":"7100000000"}`	laravel.log

Event	Sample log line (fake values)	Where it is written
Visitor tracking error	`[2026-11-02 15:00:01] qa.WARNING: Visitor tracking failed: Deadlock found when trying to get lock {"exception":"..."}`	laravel.log
reCAPTCHA rejection	`[2026-11-02 15:10:44] qa.WARNING: reCAPTCHA rejected {"error_codes":[],"score":0.1,"hostname":"mw.realty.mightywarnersdemo.com","action":"contact"}`	laravel.log
Job permanently failed	Row in `failed_jobs`: uuid `0f0e...-test`, connection `database`, queue `default`, payload class `App\Jobs\ImportFacebookLead`, exception text	failed_jobs table (`php artisan queue:failed`)
Scheduled command summary	`Closed 2 unreviewed ad(s). / Sent 3 follow-up reminder(s). / Pruned 120 anonymous events, 4 anonymous chats and 30 unused browsers.`	Console (cron output) only

8. How to check job health

Check	Command or place	What good looks like
Is the scheduler running?	`php artisan schedule:list` shows every task with its next due time; the cron must call `schedule:run` every minute	Next-due times move forward; follow-up reminders and featured expiry happen on time
Run one scheduled task now	`php artisan schedule:test` (choose from the list) or run the command directly (section 4)	Command prints its summary line
Pending jobs	`jobs` table, column `queue` (`default` or `imports`); `php artisan queue:monitor database:default,imports:imports --max=50`	Few or no rows older than a couple of minutes
Failed jobs	`php artisan queue:failed` (reads the `failed_jobs` table)	Empty list
Retry	`php artisan queue:retry {uuid}` or `php artisan queue:retry all`	Job leaves failed_jobs and runs on the next worker pass
Remove a failed job	`php artisan queue:forget {uuid}`; `queue:flush` clears all (agree with the team first)	
Process the queue by hand	`php artisan queue:work --stop-when-empty` and `php artisan queue:work imports --queue=imports --stop-when-empty --timeout=3600`	Jobs processed, exits when empty
Import progress	CRM Leads/Properties import status screens, CRM Integrations (Facebook import_status, Property Finder sync_status)	Moves from queued to running to done; failed shows the reason
Tail the log	`php artisan pail` (laravel/pail is installed) or open storage/logs/laravel.log	No new ERROR lines during the test
Is the app up?	`GET /up`	HTTP 200
Horizon / Telescope / Pulse	Not installed in this project	Use the commands above instead